Projet d'atelier – SPA/PWA et Jakarta EE 11

EduSecure

Protection et traçabilité des documents pédagogiques

Recueil des besoins

fonctionnels et de sécurité (SRE)

Version simplifiée 1.2

Réalisé par :	EZZINE Montassar
	BEN FADHEL Zayd
	OUNI Mouhamed Amine
Encadrant :	Mohamed-Becha KAANICHE
Équipe :	Trinôme
Date :	7 novembre 2026
Statut :	Première proposition à valider

Table des matières

1 Présentation du projet **1**

2 Acteurs et fonctionnement **1**

3 Besoins fonctionnels **2**

4 Approche SRE et justification **3**

5 Actifs, confidentialité, intégrité et disponibilité **4**

6 Menaces et cas de mésusage **5**

7 Exigences de sécurité détaillées **6**

8 Exigences non fonctionnelles **9**

9 Traçabilité entre les risques et les tests **9**

10 Tests de validation et critères d'acceptation **10**

11 Suivi et maintenance des exigences **11**

12 Références et conclusion **12**

1 Présentation du projet

1.1 Contexte et problème

Un professeur partage des cours, exercices ou corrigés avec ses étudiants. Dans un simple espace de fichiers, il est difficile de savoir d'où vient une copie, à quel étudiant elle était destinée et si un document volé dans le stockage est lisible. EduSecure répond à ces trois problèmes sans demander au professeur ni à l'étudiant de chiffrer les fichiers manuellement.

1.2 Objectif général

Créer une application web simple pour **publier, personnaliser, protéger et consulter des documents PDF**. L'application est utilisable par les professeurs de toutes les spécialités : physique, langues, mathématiques, informatique, etc.

1.3 Les quatre mécanismes du projet

Mécanisme	Son utilité dans EduSecure
Watermarking	Ajouter un filigrane commun (« Université – Cours de Physique ») pour identifier la provenance du document.
Fingerprinting	Inscrire une empreinte différente dans chaque copie, afin de savoir quelle distribution a servi de point de départ à une fuite.
Chiffrement hybride	Chiffrer chaque copie PDF avec AES ; protéger ensuite sa clé AES avec la clé publique RSA de l'étudiant.
Stéganographie	Cacher la **clé AES déjà chiffrée par RSA** dans une **copie PNG de la photo de profil de l'étudiant destinataire**.

Important : l'image ne contient jamais la clé AES en clair. La stéganographie cache une information ; c'est le chiffrement RSA qui protège réellement la clé. Le serveur traite temporairement le PDF en clair : cette architecture ne protège pas contre un serveur compromis pendant la publication.

2 Acteurs et fonctionnement

2.1 Qui utilise l'application ?

Acteur	Actions principales
Professeur	Déposer un PDF, choisir les étudiants, consulter l'historique et rechercher une empreinte de copie.
Étudiant	Se connecter, enregistrer sa clé publique, gérer sa **photo de profil** et ouvrir les documents attribués.
Administrateur	Gérer les comptes et l'état du système, sans accéder aux clés privées des étudiants.

2.2 Photo de profil : l'image porteuse retenue

Chaque étudiant possède une **photo de profil** dans ses informations personnelles. Cette photo sert d'image de base à la stéganographie. Lorsqu'un cours est attribué à l'étudiant, le serveur récupère sa photo, la transforme si nécessaire en PNG sans perte et crée une **copie privée réservée à cette distribution**.

La clé AES préalablement chiffrée avec la clé publique de cet étudiant est cachée dans cette copie PNG. La **photo de profil d'origine reste inchangée** et continue à être affichée normalement dans son compte. Si le même étudiant reçoit plusieurs cours, le serveur produit un nouveau PNG porteur pour chaque cours. Ces PNG ne sont jamais publiés comme des photos de profil accessibles à tous.

En l'absence de photo valide ou suffisamment grande, la distribution est suspendue pour cet étudiant et l'application l'invite à enregistrer une photo compatible. Une nouvelle photo de profil ne modifie **jamais** les PNG déjà créés pour les anciennes distributions.

2.3 Scénario principal : un cours pour trois étudiants

1. Le professeur choisit `Cours_Mathematiques.pdf` et sélectionne Amine, Zayd et Montassar.
2. Le serveur vérifie le fichier et applique un **watermark** commun indiquant sa provenance.
3. Il crée trois copies portant chacune un **fingerprint** différent.
4. Pour chaque copie, le serveur génère une nouvelle clé AES et chiffre le PDF avec **AES-256-GCM**.
5. Le serveur chiffre cette clé AES avec la **clé publique RSA** de l'étudiant concerné (**RSA-OAEP**).
6. Il récupère la **photo de profil du destinataire**, en crée une copie PNG privée, y cache la clé AES protégée par RSA, puis sauvegarde le PDF chiffré et ce PNG sans toucher à la photo originale.
7. L'étudiant demande son cours. Son navigateur extrait la clé protégée du PNG, utilise sa **clé privée locale** et ouvre automatiquement le PDF.

Exemple : Amine et Zayd possèdent chacun une photo de profil. Pour un même cours, EduSecure crée un PNG à partir de la photo d'Amine et un autre à partir de celle de Zayd. Chacun contient *sa propre clé AES protégée*, et les photos d'origine restent identiques.

2.4 Ce que le système ne promet pas

- Le professeur et l'étudiant n'exécutent pas les opérations cryptographiques à la main : elles sont automatiques.
- Le navigateur peut demander à l'étudiant de sélectionner ou déverrouiller **localement** sa clé privée ; il ne l'envoie pas au serveur.
- Un fingerprint indique l'origine d'une copie distribuée, **pas une preuve certaine de culpabilité** du destinataire.
- Un cours déjà téléchargé en clair ne peut pas être effacé à distance par une simple révocation de compte.

3 Besoins fonctionnels

Les besoins ci-dessous correspondent à la première version (MVP). Chaque besoin possède un identifiant pour suivre son implémentation.

ID	Le système doit permettre de...	Résultat attendu
BF-01	Gérer les comptes et différencier les rôles.	Chacun accède à son espace.
BF-02	Authentifier les professeurs et étudiants.	Actions protégées sans session : refus.
BF-03	Enregistrer la clé publique d'un étudiant et en vérifier la possession de la clé privée.	Clé incorrecte rejetée.

ID	Le système doit permettre de...	Résultat attendu
BF-04	Importer un PDF conforme à la taille et au format prévus.	Faux PDF ou fichier trop gros refusé.
BF-05	Choisir explicitement les étudiants destinataires.	Aucune copie pour un compte non choisi.
BF-06	Ajouter un watermark indiquant le propriétaire du document.	Filigrane lisible sur toutes les pages visées.
BF-07	Créer une copie différente par étudiant avec un fingerprint.	Trois étudiants : trois empreintes différentes.
BF-08	Rechercher une empreinte dans un PDF suspect.	Identifié, inconnu ou inconclusif.
BF-09	Générer une clé AES aléatoire pour chaque copie et chiffrer son PDF.	Aucun PDF clair conservé au repos.
BF-10	Chiffrer chaque clé AES avec la clé publique RSA du destinataire.	Seule la bonne clé privée permet de la récupérer.
BF-11	Créer un PNG depuis la photo de profil de l'étudiant, cacher la clé AES chiffrée et vérifier son extraction.	Photo originale intacte, extraction correcte.
BF-12	Sauvegarder ensemble PDF chiffré, PNG et métadonnées.	Pas de distribution incomplète visible.
BF-13	Lister uniquement les cours attribués à l'étudiant connecté.	Pas de documents d'autres comptes.
BF-14	Ouvrir automatiquement le PDF dans le navigateur avec une clé privée locale.	Cours affiché si déchiffrement réussi.
BF-15	Afficher l'état des publications et les erreurs sans secrets.	Message clair, aucune clé divulguée.
BF-16	Consulter un historique limité aux documents de l'enseignant.	Traçabilité des opérations.
BF-17	Suspendre les futurs téléchargements d'une distribution.	Requêtes suivantes refusées.
BF-18	Gérer comptes, quotas et maintenance par un administrateur.	Aucune permission d'un autre rôle.
BF-19	Enregistrer une photo de profil de l'étudiant et vérifier son format et sa taille.	Photo adaptée à l'insertion PNG.
BF-20	Créer pour chaque document une copie PNG privée de la photo de profil du destinataire.	Une copie par distribution, sans modifier le profil.
BF-21	Signaler une photo absente, corrompue ou trop petite avant toute création de distribution.	Aucune publication partielle.

3.1 Périmètre du MVP

Le prototype traite les **PDF** jusqu'à une taille indicative de **10 MiB**, à confirmer après tests. L'interface est une SPA/PWA et le middleware repose sur Jakarta EE 11. La prise en charge des vidéos, d'une plateforme LMS réelle et la résistance absolue aux modifications des fingerprints sont hors périmètre initial.

4 Approche SRE et justification

4.1 Pourquoi étudier la sécurité dès le départ ?

Une conception qui protège seulement l'écran de connexion serait insuffisante : un étudiant pourrait deviner l'identifiant d'une copie ; un attaquant pourrait remplacer une clé publique, voler une session

ou modifier un PNG. L'approche **Shift-Left** consiste donc à définir les risques et les tests de sécurité avant de développer chaque service.

4.2 Méthode retenue

Nous choisissons **SQUARE** (*Security Quality Requirements Engineering*) du Software Engineering Institute. Cette méthode donne neuf étapes simples pour identifier, classer et vérifier les exigences de sécurité [1].

N°	Étape	Dans EduSecure
1	Définir les termes	Préciser watermark, fingerprint, clé AES, risque.
2	Fixer les objectifs	Confidentialité, intégrité, disponibilité et traçabilité.
3	Décrire le système	Acteurs, architecture, objets protégés et flux.
4	Étudier les risques	Identifier les possibilités d'attaque.
5	Choisir la collecte	Discussions avec encadrant et scénarios d'abus.
6	Écrire les exigences	Formuler les obligations avec identifiants SEC.
7	Les classer	Authentification, droits, données, audit, résilience.
8	Les prioriser	P0 : obligatoire ; P1 : important ; P2 : amélioration.
9	Les faire vérifier	Relier une exigence à un test et valider la version.

4.3 Méthodes complémentaires

- **STRIDE** aide à penser comme l'attaquant : usurpation, modification, contestation, divulgation, indisponibilité et élévation de privilèges.
- **Misuse Cases** décrivent ce que l'application ne doit pas permettre : « lire la copie d'un autre étudiant ».
- **OWASP ASVS** sert de base technique pour vérifier les contrôles web [2].

Justification : SQUARE organise les besoins ; STRIDE repère les menaces ; les cas de mésusage et ASVS permettent de construire les tests. OCTAVE et SERA sont utiles dans d'autres contextes, mais plus complexes à déployer pour ce prototype de trinôme.

État du travail : il s'agit d'une première analyse. Les exigences et leurs priorités seront ajustées avec l'encadrant, les tests et l'agenda de sécurité du cours.

5 Actifs, confidentialité, intégrité et disponibilité

5.1 Que doit-on protéger ?

Actif	Risque principal
PDF du professeur	Lecture par un tiers ou transformation non autorisée.
Copie de chaque étudiant	Accès par un autre étudiant, fuite ou altération.
Clé AES de chaque copie	Divulgation permettant le déchiffrement du cours.
Clé privée étudiante	Vol ou transmission par erreur au serveur.
Clé publique enregistrée	Remplacement par une clé contrôlée par l'attaquant.
Image PNG et PDF chiffré	Perte, échange entre comptes ou modification.
Registre des fingerprints	Attribution incorrecte et exposition de données personnelles.
Comptes et journaux	Usurpation, abus de privilège ou suppression des traces.
Photos de profil et PNG dérivés	Données personnelles exposées ou image publique remplacée par une version stéganographiée.

5.2 Le triptyque CIA dans notre application

- **Confidentialité (C) :** seul l'étudiant autorisé peut obtenir sa distribution ; les documents sont chiffrés au repos, les clés privées restent locales.
- **Intégrité (I) :** un PDF chiffré modifié échoue à la vérification AES-GCM ; les PNG et empreintes ne doivent pas être échangés entre étudiants.
- **Disponibilité (A) :** le service doit résister à des fichiers trop gros, traiter les échecs correctement et permettre une restauration des données.

6 Menaces et cas de mésusage

6.1 Principaux risques à traiter

ID	Attaque possible	Protection prévue
R-01	Un étudiant change l'identifiant d'un PDF pour lire celui d'un autre.	Contrôle des droits sur *chaque* fichier et PNG.
R-02	Un attaquant remplace la clé publique d'un étudiant.	Vérification de la clé et traçabilité des changements.
R-03	La clé privée est transmise ou exposée par le site.	Traitement local dans le navigateur ; aucun upload.
R-04	Une personne vole les fichiers du stockage.	AES-GCM pour les documents ; RSA-OAEP pour les clés.
R-05	Un PNG ou un document chiffré est modifié.	Contrôle d'extraction et d'intégrité avant affichage.
R-06	Un PDF malveillant bloque ou attaque le serveur.	Validation du format, quotas et limites de traitement.
R-07	Un utilisateur modifie ou retire un fingerprint.	Tests de robustesse ; résultat « inconclusif » possible.
R-08	Un attaquant vole un compte ou une session.	Authentification, expiration, contrôle des rôles et journaux.
R-09	Des requêtes massives saturent le traitement.	Limitation de débit et de concurrence.
R-10	Le serveur est compromis pendant la publication.	Durcissement ; risque résiduel clairement déclaré.
R-11	Un PNG stéganographié est publié comme photo de profil.	Conserver l'original ; PNG de distribution privé et soumis aux droits.
R-12	La photo est absente, corrompue ou trop petite.	Validation et erreur explicite avant publication.

6.2 Cinq cas de mésusage concrets

1. **Accès à la copie d'autrui :** Zayd modifie l'identifiant dans une URL. Le serveur doit refuser l'accès au PDF, au PNG et aux métadonnées.
2. **Substitution de clé publique :** l'attaquant enregistre une fausse clé à la place de celle d'Amine. La publication doit être bloquée si la clé n'est pas vérifiée.
3. **Altération du PNG :** un fichier image est recompressé et le message caché est perdu. L'application doit détecter l'erreur et ne rien déchiffrer.
4. **Faux fichier PDF :** un programme est renommé `cours.pdf`. Le serveur doit le rejeter sans l'exécuter.
5. **Fuite par la photo de profil :** un utilisateur tente d'obtenir la copie PNG cachant la clé en consultant simplement une fiche étudiante. La fiche n'affiche que la photo d'origine ; le PNG de distribution exige les droits du destinataire.

7 Exigences de sécurité détaillées

Les règles ci-dessous sont **communes à tous les membres de l'équipe**. Chaque ligne dit ce que le système doit faire et comment nous le vérifierons. **P0** = indispensable ; **P1** = important ; **P2** = amélioration.

7.1 Identification et authentification

ID	Exigence à respecter	Comment vérifier ?
SEC-ID-01	Chaque personne possède un identifiant unique et un rôle connu. **P0**	Deux comptes ne partagent pas le même identifiant.
SEC-AUT-01	Le professeur, l'étudiant et l'administrateur s'authentifient avant les actions sensibles. **P0**	Accès sans session refusé.
SEC-AUT-02	Les mots de passe ne sont jamais stockés en clair ; un hachage résistant avec sel est utilisé. **P0**	Inspection des données de test.
SEC-AUT-03	Les sessions expirent et utilisent des cookies protégés sous HTTPS. **P0**	Session expirée inutilisable.
SEC-AUT-04	Les tentatives de connexion répétées sont limitées et suivies. **P1**	Rafale d'essais détectée.

7.2 Autorisation et protection des ressources

ID	Exigence à respecter	Comment vérifier ?
SEC-DRO-01	Le serveur vérifie le rôle à chaque requête, sans accepter un rôle fourni par le navigateur. **P0**	Tests croisés des trois rôles.
SEC-DRO-02	Seul le professeur propriétaire consulte ou modifie ses publications. **P0**	Un autre prof est refusé.
SEC-DRO-03	Un étudiant n'accède qu'aux copies qui lui sont attribuées. **P0**	Tests d'identifiants modifiés.
SEC-DRO-04	Les mêmes droits protègent PDF chiffré, PNG et métadonnées ; aucun stockage public. **P0**	Quatre tests de téléchargement.
SEC-DRO-05	La révocation bloque les nouveaux téléchargements ; une copie déjà sortie reste hors du contrôle de l'application. **P1**	Test avant/après révocation.

7.3 Confidentialité et gestion des clés

ID	Exigence à respecter	Comment vérifier ?
SEC-CON-01	Tous les échanges de production passent par HTTPS. **P0**	Aucun upload en HTTP clair.
SEC-CON-02	Le stockage permanent ne contient aucun PDF ni clé AES en clair. **P0**	Inspection des fichiers et DB.
SEC-CLE-01	Le serveur génère une nouvelle clé AES-256 aléatoire pour chaque copie. **P0**	Clés différentes sur trois copies.
SEC-CLE-02	Les PDF sont chiffrés par AES-GCM, avec nonce unique par clé et paramètres de déchiffrement versionnés. **P0**	Chiffrement puis déchiffrement.
SEC-CLE-03	Le serveur chiffre la clé AES avec RSA-OAEP-SHA-256 sous la bonne clé publique. **P0**	Mauvaise clé privée : échec.
SEC-CLE-04	La clé publique est reliée à un compte et vérifiée avant publication ; ses changements sont suivis. **P0**	Fausse clé refusée.
SEC-CLE-05	La clé privée reste sur l'appareil de l'étudiant et ne part jamais vers l'API. **P0**	Capture du trafic réseau.

Suite des exigences de sécurité

ID	Exigence à respecter	Comment vérifier ?
SEC-CON-03	Le frontend et les logs ne conservent aucune clé AES claire ni le PDF déchiffré. **P0**	Inspection cache et journaux.
SEC-CLE-06	Une perte de clé privée est signalée : le serveur ne prétend pas pouvoir déchiffrer les anciennes copies. **P1**	Scénario de perte expliqué.

7.4 Stéganographie, intégrité et traçabilité

ID	Exigence à respecter	Comment vérifier ?
SEC-STE-01	La copie PNG tirée de la photo de profil ne cache que la clé AES *déjà chiffrée* par RSA, jamais la clé claire. **P0**	Contrôle du contenu inséré.
SEC-STE-02	Le PNG est conservé sans recompression ni conversion destructive. **P0**	Octets restitués identiques.
SEC-STE-03	La capacité du PNG est vérifiée, puis l'extraction est testée après sauvegarde. **P0**	Essais avec petit/grand PNG.
SEC-STE-04	La photo originale du profil ne change jamais ; la copie PNG contenant la clé n'est pas accessible publiquement. **P0**	Comparer la photo et les autorisations.
SEC-STE-05	Une photo JPEG peut être convertie en PNG sans perte pour l'insertion ; photo invalide ou trop petite : refus expliqué. **P0**	Essais JPEG, image corrompue et petite.
SEC-STE-06	Chaque distribution dispose de son propre PNG immuable, y compris pour plusieurs cours d'un même étudiant. **P0**	Deux cours donnent deux PNG distincts.
SEC-INT-01	Une modification du fichier chiffré, du nonce ou des paramètres associés bloque le déchiffrement. **P0**	Modifier un octet : échec.
SEC-INT-02	Le watermark reste lisible et le fingerprint est unique par copie. **P0**	Trois PDF et trois empreintes.
SEC-INT-03	Le registre des fingerprints ne peut être modifié que par les services autorisés. **P1**	Tentative de modification refusée.
SEC-INT-04	Une recherche d'empreinte ne conclut pas lorsqu'elle ne dispose pas d'indices suffisants. **P1**	Cas « inconclusif » vérifié.

7.5 Audit, non-répudiation et détection

ID	Exigence à respecter	Comment vérifier ?
SEC-AUD-01	Le système enregistre connexions, publications, accès refusés, changements de clés et erreurs. **P0**	Événements présents.
SEC-AUD-02	Les journaux ne contiennent ni mots de passe, ni clés privées, ni clés AES claires. **P0**	Recherche des secrets tests.
SEC-AUD-03	Chaque événement garde date, acteur, ressource et résultat ; les logs sont protégés des utilisateurs ordinaires. **P1**	Audit de deux comptes.
SEC-AUD-04	Les comportements répétés suspects (échecs de connexion, accès interdits) peuvent déclencher une alerte. **P1**	Rafale contrôlée.
SEC-NRP-01	La publication garde l'identité de l'enseignant et un horodatage ; une simple trace ne constitue pas une preuve juridique forte. **P1**	Historique et limite affichés.

7.6 Résilience et sécurité de l'application

ID	Exigence à respecter	Comment vérifier ?
SEC-DIS-01	Les tailles des fichiers, nombre de pages et traitements simultanés sont plafonnés. **P0**	Gros fichier rejeté.
SEC-DIS-02	Une erreur de traitement ne crée pas de distribution incomplète. **P0**	Simulation de panne.
SEC-DIS-03	La sauvegarde restaure ensemble base, PDF chiffré et PNG. **P1**	Essai de restauration.
SEC-WEB-01	La PWA ne met pas les PDF clairs ni les secrets dans son cache permanent. **P0**	Contrôle du cache navigateur.
SEC-WEB-02	Les champs non fiables ne provoquent pas de XSS ; les opérations sensibles protègent contre CSRF. **P0**	Tests XSS et CSRF.
SEC-UPL-01	Le serveur vérifie le type réel, la taille et la structure des PDF envoyés. **P0**	Faux PDF rejeté.
SEC-UPL-02	Les photos de profil sont validées (type réel, dimensions, taille et contenu image) avant traitement. **P0**	Fausse image rejetée.
SEC-DEV-01	Les secrets sont exclus de GitHub ; les tests fonctionnels et de sécurité passent dans la CI. **P1**	Revue d'une pull request.

8 Exigences non fonctionnelles

Qualité	Objectif et moyen de contrôle
Simplicité	L'enseignant dépose et attribue un cours en quelques étapes ; l'étudiant n'a pas besoin de connaître AES ou RSA.
Performance	Mesurer le temps de traitement des PDF jusqu'à 10 MiB pour 1 puis 3 destinataires ; fixer un seuil après les tests.
Disponibilité	Prévoir le redémarrage après erreur et une restauration. RPO 24 h et RTO 4 h sont des hypothèses de prototype à confirmer.
Maintenabilité	Séparer modules PDF, fingerprint, crypto, stéganographie et API ; documenter les endpoints et tests.
Compatibilité	Navigateur moderne avec Web Crypto ; interface SPA/PWA adaptée au PC et au mobile, sans cache de PDF clair.
Observabilité	Compteurs de publications réussies/échouées, erreurs et refus d'accès sans exposer de données sensibles.

9 Traçabilité entre les risques et les tests

Une exigence est utile si l'équipe sait **quel risque elle réduit** et **quel test la vérifie**. Cette matrice donne les liens essentiels. Les identifiants restent identiques dans les issues GitHub.

Risque	Exigences liées	Preuve prévue
R-01	SEC-DRO-03, SEC-DRO-04	T-06 : copie d'un autre compte refusée.
R-02	SEC-CLE-04	T-07 : fausse clé publique rejetée.
R-03	SEC-CLE-05, SEC-CON-03	T-12 : aucune clé privée envoyée.
R-04	SEC-CON-02, SEC-CLE-01 à 03	T-02, T-04 : fichiers protégés.
R-05	SEC-STE-02/03, SEC-INT-01	T-03, T-05, T-09 : altération détectée.
R-06	SEC-UPL-01, SEC-DIS-01	T-08 : fichier hostile refusé.
R-07	SEC-INT-02/04	T-01, T-10 : empreinte contrôlée.
R-08	SEC-AUT-01 à 04	T-13 : tentatives suspectes suivies.
R-09	SEC-DIS-01/02	T-08, T-14 : traitement borné.
R-10	SEC-DEV-01, SEC-AUD-01	Revue de code et *risque résiduel* déclaré.
R-11	SEC-DRO-04, SEC-STE-04/06	T-17, T-18, T-20 : photo préservée, PNG privé.
R-12	SEC-STE-03/05, SEC-UPL-02	T-19 : photo incompatible rejetée.

10 Tests de validation et critères d'acceptation

Les tests démontrent concrètement que les exigences sont remplies.

Test	Action de test	Résultat attendu
T-01	Publier un PDF pour trois étudiants.	Un watermark, trois copies fingerprintées.
T-02	Inspecter le stockage après publication.	Aucun document/clé AES clair.
T-03	Extraire la clé chiffrée des trois PNG.	Octets identiques aux données insérées.
T-04	Déchiffrer avec la bonne puis une mauvaise clé privée.	Succès puis refus.
T-05	Modifier un octet du ciphertext AES-GCM.	Authentification échouée.
T-06	Étudiant A demande PDF, PNG et métadonnées de B.	Toutes les requêtes refusées.
T-07	Enregistrer une clé publique non vérifiée.	Publication bloquée pour ce compte.
T-08	Importer un faux PDF et un fichier trop grand.	Rejet sans exécution.
T-09	Recompresser ou modifier un PNG.	Erreur d'extraction détectée.
T-10	Rechercher un fingerprint connu puis absent.	Identifié puis inconnu/inconclusif.
T-11	Déconnecter l'étudiant et examiner le cache PWA.	Pas de PDF clair stocké.
T-12	Observer le trafic quand l'étudiant utilise sa clé privée.	Aucun upload de clé privée.
T-13	Répéter des échecs de connexion et accès interdits.	Logs et limitation visibles.
T-14	Interrompre la génération d'une distribution.	Pas d'objet publié à moitié.
T-15	Restaurer une sauvegarde de trois copies.	Couples PDF/PNG cohérents.
T-16	Tenter XSS/CSRF sur les fonctions de publication.	Entrée neutralisée / action refusée.
T-17	Comparer la photo de profil avant et après attribution.	Photo originale strictement inchangée.
T-18	Attribuer deux cours à un même étudiant.	Deux PNG privés, chacun lié à son document.
T-19	Publier pour un profil sans photo, avec image corrompue ou trop petite.	Erreur claire, aucune distribution partielle.

Test	Action de test	Résultat attendu
T-20	Accéder à la photo publique puis au PNG de distribution sans droit.	Photo seule visible ; PNG protégé.

Définition de « Terminé » : le parcours métier marche, les contrôles de sécurité critiques ont passé les tests (notamment la préservation de la photo de profil), et les résultats sont liés à une issue ou pull request GitHub.

10.1 Conditions minimales pour la démonstration

- Un professeur peut publier un PDF pour trois étudiants disposant chacun d'une photo de profil valide, et retrouver la provenance ainsi que trois fingerprints distincts.
- Chaque étudiant récupère seulement sa copie ; la bonne clé privée permet de la lire, une clé incorrecte ou un fichier altéré ne le permet pas.
- Les tests critiques d'accès croisé, de protection des clés, d'upload, de cohérence PDF/PNG et de préservation des photos originales sont exécutés et documentés.

11 Suivi et maintenance des exigences

11.1 Comment faire évoluer le recueil ?

1. Créer une issue GitHub avec l'identifiant du besoin, le problème observé et sa justification.
2. Vérifier les risques et les exigences touchés ; modifier les tests si nécessaire.
3. Faire relire la modification par un autre membre, puis valider les décisions importantes avec l'encadrant.
4. Mettre à jour la version du PDF dans `docs/` et conserver l'historique des changements.

11.2 Répartition de travail proposée

Membre	Responsabilité principale
EZZINE Montassar	Stéganographie de la clé dans une copie privée de photo de profil, parcours PWA et tests de récupération.
BEN FADHEL Zayd	Watermarking, fingerprinting et détection des copies.
OUNI Mouhamed Amine	Architecture Jakarta EE, chiffrement, API et suivi SRE.

Responsabilité commune : tous les membres testent les exigences de sécurité, même si leurs modules métier diffèrent.

11.3 Questions ouvertes pour la séance suivante

- Quel niveau de robustesse du fingerprint faut-il démontrer (PDF intact, impression, conversion en image) ?
- Comment l'étudiant sauvegarde-t-il sa clé privée localement ?
- Quelles limites exactes de taille, nombre de destinataires et conservation des données seront demandées ?
- Quelles exigences supplémentaires de sécurité seront ajoutées pendant l'atelier ?

12 Références et conclusion

12.1 Référentiels

Références

[1] Carnegie Mellon / Software Engineering Institute, *Security Quality Requirements Engineering (SQUARE)*. https://www.sei.cmu.edu/library/security-quality-requirements-engineering-square/.

[2] OWASP, *Application Security Verification Standard (ASVS), version 5.0.0*. https://asvs.owasp.org/.

[3] NIST, *SP 800-57 : Key Management*. https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final.

[4] W3C, *Web Cryptography API*. https://www.w3.org/TR/webcrypto-1/.

12.2 Conclusion

EduSecure réunit **watermarking**, **fingerprinting** et **stéganographie** pour diffuser des copies PDF traçables et protégées. La stéganographie repose sur une copie PNG de la **photo de profil de chaque étudiant**, tout en préservant l'image originale. Ce recueil précise les besoins métier, les principaux risques, les exigences de sécurité et les tests à réaliser. La méthode SQUARE aide l'équipe à maintenir ces exigences dès la conception ; le document évoluera à mesure que le cours et les validations avancent.